

Privacy by Design in AI-Assisted Cybersecurity Policy Generation: Benchmarking Private RAG Against Frontier AI Models

Davide Carboni and M. Marcello Verona

The Lisbon Council, Brussels, Belgium
`marcello.verona@lisboncouncil.net`

Abstract. The NIS 2 Directive and GDPR impose on regulated EU organisations a growing policy compliance gap: the obligation to produce context-specific cybersecurity policy artefacts has outpaced internal capacity to create them. Large language models offer scalable assistance, but effective policy generation requires routing sensitive organisational data through an inference pipeline. Under GDPR Arts. 28, 32, and 44–49, this creates a structural tension: the data required to generate a useful policy is precisely the data that cannot be processed without adequate legal safeguards.

We present a controlled empirical benchmark comparing six AI configurations spanning the design space from unaugmented frontier chat to privacy-by-design private RAG. Sixty policy artefacts were generated across two regulated contexts — a fictitious Italian public hospital and a fictitious NATO detachment, constructed as representative synthetic profiles with no connection to real entities — and five policy types, then evaluated by an LLM-as-judge pipeline using a seven-criterion rubric derived from the Anthropic agent evaluation framework and extended with three cybersecurity compliance dimensions.

The best frontier configuration (gpt-5.5 + web search) achieves a mean score of 4.60/5; the private RAG configuration (Kimi K2.5 on EU-resident infrastructure under a DPA) scores 4.15/5 — a 9 % gap. The OpenAI Assistants RAG configuration falls below the no-RAG baseline (3.70 vs. 3.83), suggesting that cloud-hosted RAG does not automatically improve output quality. A backbone ablation (10/0 pairwise comparisons, Kimi K2.5 over DeepSeek V3.2) isolates normative citation discipline as the decisive differentiator. Under the EC Cloud Sovereignty Framework, the private RAG architecture classifies at SEAL-2; frontier configurations qualify at SEAL-0. The 9 % quality gap is identified as the operational cost of regulatory-grade data sovereignty.

Keywords: cybersecurity policy generation · large language models · retrieval-augmented generation · data sovereignty · privacy-preserving AI · LLM evaluation

1 Introduction

The NIS2 Directive [7] extends mandatory cybersecurity obligations to over 160,000 organisations across the EU — healthcare, energy, transport, public administration, defence supply chains — many of which previously operated without formal information security policies. Combined with GDPR [6] and the AI Act [8], regulated organisations now face a growing policy compliance gap: the legal requirement to produce, maintain, and audit cybersecurity policy artefacts has outpaced the internal capacity to create them. The burden falls hardest on resource-constrained organisations — a regional hospital with a single IT manager, a small NATO support unit without a dedicated CISO — for which producing context-specific, regulation-aligned policies from scratch represents a prohibitive cost in both expertise and time.

Frontier AI models offer a compelling response: scalable, on-demand access to expertise that would otherwise require external consultants. The effectiveness of AI-assisted policy generation has begun to be validated [13,10]. Yet effective policy generation is not a one-shot task. A policy that does not reflect the organisation’s actual asset inventory, threat model, regulatory regime, and operational constraints is at best a template and at worst a compliance artefact that conveys false assurance. Context-elicitation — a structured dialogue that gathers organisational specifics before drafting — is therefore essential to output quality.

Here lies a fundamental tension. The data required to generate a useful policy is by definition sensitive: organisational structure, known vulnerabilities, gap analyses, incident history, cloud footprint. Under GDPR Arts 28, 32, and 44–49 [6], organisations in regulated sectors cannot route this data through processors without an adequate Data Processing Agreement (DPA), let alone across extra-EU boundaries without a transfer mechanism. A healthcare provider generating its data protection policy through a consumer-tier frontier assistant is, structurally, already in violation of the regime the policy is meant to implement. The industry has responded with two patterns: cloud RAG on proprietary providers (OpenAI Assistants, Azure OpenAI) — which improves grounding but does not address EU data residency, open-weight portability, or DPA; and private RAG on EU-resident open-weight models — which addresses all three. Yet no prior study evaluates output quality and privacy compliance of the underlying inference architecture simultaneously under the same evaluation rubric. Figure 1 illustrates the three architectural patterns and their respective EU data perimeters.

Research question: *Does a well-architected private RAG system (EU-region + DPA + open-weight) produce cybersecurity policies of comparable or superior quality to frontier AI models, while remaining consistent with GDPR data-processing obligations by design?*

We address this question by contributing: (i) an empirical benchmark comparing six AI configurations on 60 policy generation tasks in two regulated contexts; (ii) a controlled pairwise ablation for backbone selection within the same RAG architecture; and (iii) a joint quality-and-privacy evaluation framework applicable to regulated deployment contexts.

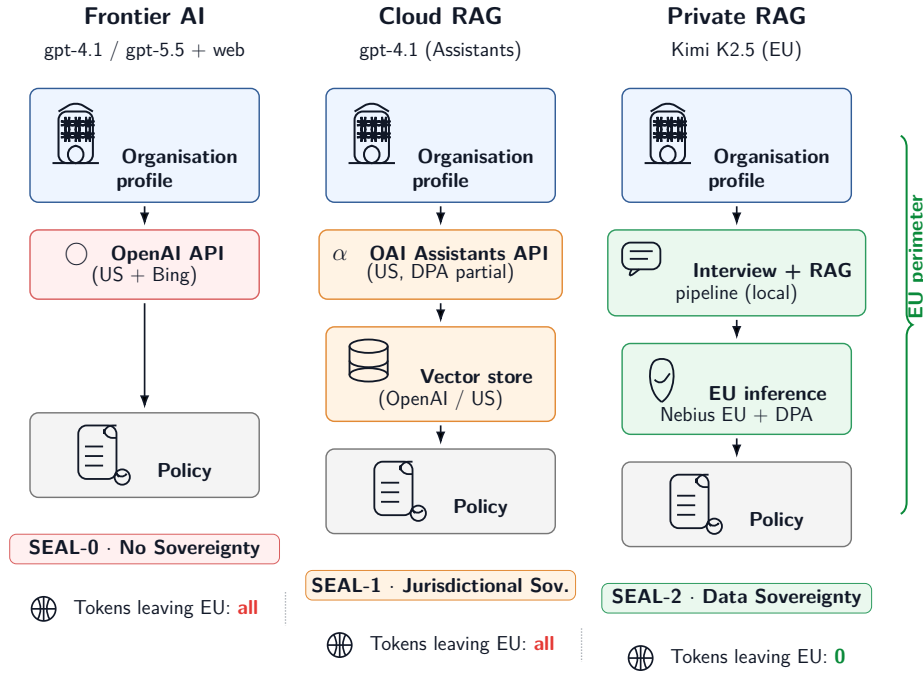


Fig. 1. The three architectural patterns benchmarked in this study. The green bracket in the Private RAG column indicates that no data leaves the EU perimeter. SEAL levels follow the EC Cloud Sovereignty Framework [5].

2 Related Work

LLM-based cybersecurity policy generation is an emerging area. McIntosh et al. [13] demonstrated that GPT-4 can generate GRC policies that outperform human-written ones in certain ransomware mitigation contexts; the study relies on human moderation and legal expert oversight throughout — an implicit acknowledgement that data handling risks are unresolved. Jawhar et al. [10] similarly demonstrate AI effectiveness for security policy and procedure drafting without addressing GDPR or data residency constraints. In both cases, quality is assessed informally without a replicable evaluation rubric, and no privacy-compliant architecture is tested.

LLM-as-judge methodology provides the evaluation backbone for our study [1]. Zheng et al. [16] demonstrate that GPT-4 as a judge reaches over 80% agreement with human experts on instruction-following tasks; positional and verbosity biases can be partially mitigated by swapping answer positions and using chain-of-thought prompting. Liu et al. [12] introduce G-Eval, a form-filling framework with probability-weighted scoring that correlates more strongly with human judgement than string-overlap metrics. Human calibration of automated

rubrics is typically quantified via Cohen’s κ ; Dubois et al. [3] provide a methodological baseline for this calibration step in the context of preference evaluation.

The deployment of AI for cybersecurity policy generation in regulated organisations raises privacy constraints that go beyond GDPR surface compliance. Two distinct properties must be distinguished: *data residency* — the physical location of storage and processing, including logs, backups, and telemetry — and *data sovereignty* — the legal jurisdiction governing the provider and its sub-processor chain [6,2]. A provider incorporated outside the EU may retain legal exposure even when operating EU-located servers: the US Clarifying Lawful Overseas Use of Data Act (CLOUD Act) [15] permits US authorities to compel disclosure of data held by US-incorporated entities regardless of physical location. An additional risk vector is the sub-processor chain: a provider with EU legal domicile may add an extra-EU sub-processor unilaterally, extending the exposure perimeter without customer notification [6]. Existing benchmarks of AI-assisted cybersecurity policy generation [13,10] evaluate output quality in isolation; to our knowledge, no prior work simultaneously evaluates output quality and the privacy compliance of the underlying inference architecture within a unified framework.

3 Methodology

3.1 Experimental Design

The study adopts a two-phase design. In the first phase, a backbone selection experiment compares two open-weight models running on an identical private RAG architecture, in order to select the stronger candidate before the full benchmark. In the second phase, the selected private RAG configuration is benchmarked against four frontier AI configurations spanning the design space from unaugmented chat to cloud-hosted RAG.

All policy artefacts are generated from synthetic organisational profiles designed to represent typical regulated-sector environments (see Section 4). The use of synthetic data allows full control over the experimental conditions and avoids any real data privacy concern in the evaluation pipeline itself.

3.2 Policy Generation

Each artefact is produced through a single prompt containing the full organisational profile, eliciting the policy in one response (*rapid-policy* mode). The online deployment of PolicyCoach gathers the same profile through a 6–8-turn adaptive interview before generating the policy; for the benchmark, the interview output is rendered once per context from a structured YAML, equalising the input across all six configurations and isolating the policy-generation step as the single variable under test. The private RAG configurations augment this generation with retrieval from a curated knowledge base of 837 chunks drawn from NIST CSF 2.0, ISO/IEC 27001:2022, GDPR, NIS2, the AI Act, and sector-specific guidance for healthcare and defence. Frontier configurations either use no augmentation or rely on live web search.

3.3 Evaluation Framework

Each artefact is evaluated by an LLM-as-judge pipeline using Claude Opus 4.7 as the scoring model, following the structured grader blueprint described in [1]. The judge receives three inputs: the generated policy, the synthetic organisational profile used during generation, and a detailed scoring rubric. It returns a score from 1 to 5 on each of seven quality dimensions (see Section 4.3), accompanied by a brief scoring rationale.

The judge is invoked once per (artefact, criterion) pair with temperature 0.0, scoring one dimension at a time to prevent cross-criterion anchoring. The judge receives no configuration label or model identifier, eliminating self-preference and provenance-based bias in scoring. Following the Anthropic “escape valve” principle [1], the judge returns *insufficient_evidence* (null) rather than guess when a criterion has no observable signal in the policy; null scores are excluded from per-configuration means. In our benchmark this occurred 5 times across 350 artefact–criterion evaluations (1.4%), predominantly on the *Resource consideration* dimension.

The rubric combines objective checks — for example, presence of specific regulatory citations or mandatory policy clauses — with holistic LLM-scored assessments of coherence and contextual fit. This two-layer structure reduces sensitivity to surface variation while preserving sensitivity to substantive quality differences. To validate the rubric, two rounds of human calibration were conducted. The first round was carried out by experts with ISO/IEC 27001 knowledge, scoring Password Policy artefacts representing opposite ends of the quality spectrum (judge mean 4.71/5 vs. 2.43/5) on all seven criteria, yielding Cohen’s weighted $\kappa_w = 0.65$ (*substantial agreement*, Landis and Koch [11]). A second, post-submission round extended the calibration with three external raters from two COcyber Advisory Board organisations (GuardedBox, ES; Universidad Internacional de La Rioja, ES), scoring two policy pairs (Password and Incident Response) drawn from the same calibration bundles. Pooled across the 37 criterion–artefact pairs with non-missing human scores, the extended calibration yields $\kappa_w = 0.28$ (*fair agreement*). Rank ordering was fully preserved across all three rater–bundle combinations (binary rank-ordering $\kappa = 1.0$): every rater assigned a higher mean score to the frontier-model output than to the private-RAG output. A noteworthy pattern emerged on C4 (*Implementability*) and C7 (*Resource consideration*), where one rater panel assigned higher scores to the private-RAG output, attributing this to the frontier model’s verbosity being potentially excessive for a non-specialised hospital manager — a practically relevant dimension that the LLM judge does not fully capture. The lower κ_w in the extended round, compared with the initial calibration, reflects the broader diversity of rater backgrounds and calibration lenses (compliance expertise vs. operational practitioner perspective); the rank-ordering result confirms that the judge’s core comparative signal is robust.

Rubric design rationale. The seven dimensions were derived in two steps. First, we mapped the grading dimensions proposed by Anthropic for research agents [1]

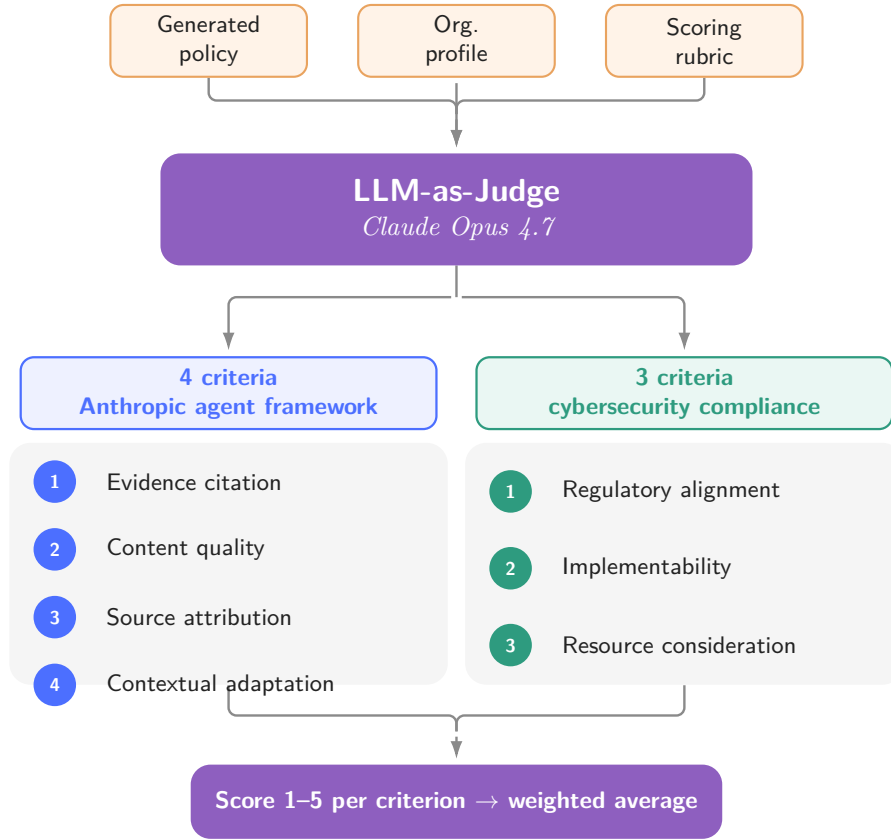


Fig. 2. LLM-as-judge evaluation pipeline. Four criteria are mapped from the Anthropic research agent grading framework [1]; three are added for the cybersecurity compliance domain.

— groundedness of claims against sources, coverage of key facts, source quality, and coherence of synthesis — onto the policy generation task, yielding *Evidence citation*, *Content quality*, *Source attribution*, and *Contextual adaptation* respectively. Second, we extended the rubric with three dimensions specific to the cybersecurity compliance domain: *Regulatory alignment* (coverage of applicable regulatory obligations, absent in generic agent evals); *Implementability* (actionability under real operational constraints); and *Resource consideration* (fitness for SME and public-sector organisations where budget and staffing are primary constraints). The extended rubric is publicly available with the evaluation code. Figure 2 summarises the evaluation pipeline and the derivation of the seven criteria.

Table 1. Experimental configurations. GDPR compliance denotes the ability to operate under GDPR Art. 28 (DPA), Art. 32 (security measures), and Art. 44–49 (third-country transfers) as assessed from available provider documentation. † OpenAI Assistants API provides a DPA for API customers but does not guarantee EU data residency; data may be processed under SCCs outside the EU. ‡ SEAL-2 per-objective assessment: Table 3.

Model	Knowledge		GDPR
	Base	Web Provider	
gpt-4.1	–	– OpenAI consumer	×
gpt-4.1 + web search	–	✓ OpenAI + Bing	×
gpt-5.5 + web search	–	✓ OpenAI + Bing	×
gpt-4.1 (OpenAI Assistants RAG)	✓	– OpenAI Assistants partial†	
Kimi K2.5 (private RAG)	✓	– Nebius EU + DPA	✓‡
DeepSeek V3.2 (private RAG)	✓	– Nebius EU + DPA	✓

4 Experimental Setup

4.1 Configurations

We compared six configurations spanning the design space from consumer-tier AI chat to privacy-compliant private RAG (Table 1).

The first four configurations offer no EU data residency guarantee. The private RAG configurations (Kimi K2.5 and DeepSeek V3.2) are privacy-by-design: all inference runs within a Nebius EU region under a DPA, using open-weight models whose weights can be independently audited.

4.2 Backbone Selection

Before the full benchmark, we compared Kimi K2.5 and DeepSeek V3.2 under strictly identical conditions — same curated KB, identical system prompt, same EU-region provider (Nebius), and no model-specific prompt tuning. This controlled ablation isolates the backbone model as the sole variable, ruling out architecture or prompt design as confounds.

4.3 Evaluation Contexts and Policy Types

Each configuration was tested across two regulated contexts: **ctx-H** (a small Italian public hospital, ≈ 200 staff, subject to Italian healthcare regulations, NIS2, and GDPR) and **ctx-M** (a NATO detachment in Romania, subject to NATO information security policy). Both are *fictitious* organisational profiles constructed to be representative of their respective sectors; no data from real entities was used at any stage of the study. Five policy types were generated per context: Password Policy, Data Protection Policy, Access Control Policy, Incident Response Policy, and General Cybersecurity Policy, yielding 60 artefacts in total.

Each artefact was evaluated on seven quality dimensions (Section 3.3) with 1–5 Likert anchors:

1. **Content quality:** accuracy and completeness of cybersecurity controls
2. **Contextual adaptation:** fit to the specific organisational context
3. **Evidence citation:** grounding in standards and regulatory sources
4. **Implementability:** actionability and practical feasibility
5. **Regulatory alignment:** coverage of applicable compliance requirements
6. **Source attribution:** traceable references to cited sources
7. **Resource consideration:** acknowledgement of organisational resource constraints

5 Results

5.1 Backbone Selection: Kimi K2.5 vs. DeepSeek V3.2

The pairwise judge returned 10/10 comparisons in favour of Kimi K2.5 over DeepSeek V3.2. Both models ran on the same private RAG architecture with identical system prompt and KB; the result is attributable solely to the models’ differential ability to follow structured citation directives. The gap is concentrated on normative traceability: source attribution (4.10 vs. 2.30, $\Delta = 1.80$) and regulatory alignment (4.20 vs. 2.90, $\Delta = 1.30$). Implementability is the sole dimension where the models converge ($\Delta = 0.60$, 3 ties). Kimi K2.5 was selected as the private RAG backbone for the full benchmark.

The pairwise outcome is consistent with the full-benchmark scoring: across the same matched set of ten artefacts per configuration, DeepSeek V3.2 averaged 3.12/5 versus Kimi K2.5’s 4.15/5 — a 1.03-point gap, larger than the 0.45-point gap between Kimi K2.5 and the best frontier configuration (gpt-5.5 + web; cf. Table 2). The backbone-selection step is therefore methodologically necessary: the choice of open-weight backbone contributes more to output quality than the choice between the selected private RAG and the best frontier system. The gap reflects two distinct mechanisms. The first is the systematic deficit in normative traceability already reported above. The second is a generation-robustness failure observed on one DeepSeek artefact, in which a token-repetition loop iterated the string “Govern” throughout the NIST CSF compliance section, rendering that portion of the policy unusable; Kimi K2.5 produced no comparable failures across the matched set. Generation robustness under structured policy prompts is itself a legitimate selection criterion for a production private RAG backbone and is reported here alongside the quality gap.

5.2 Quality Scores Across Configurations

Table 2 reports mean scores across all ten artefacts per configuration (two contexts $\times$ five policy types), with per-configuration standard deviation in the row below. gpt-5.5 + web search achieves the highest average (4.60, SD 0.82), followed by Kimi K2.5 private RAG (4.15, SD 0.94) and gpt-4.1 + web search (3.90, SD 0.89). The OpenAI Assistants RAG configuration falls below the no-RAG gpt-4.1 baseline on the overall average.

Table 2. Mean quality scores by configuration (1–5 Likert scale). Bold: highest value per row. DeepSeek V3.2 was eliminated after backbone selection (Section 5.1) and is not included here. Cost estimates based on average token counts from generation logs and API list prices (May 2026). Latency: median wall-clock time, client-side. * gpt-5.5 cost reflects token usage at OpenAI short-context list prices (\$5.00 / \$30.00 per 1M input / output) and does not include web_search_preview tool fees, which add an estimated \$0.30 per query (12.4 calls per query at typical tool pricing) bringing the all-in cost to ~\$1.08 per query. Kimi K2.5 cost computed from Nebius list prices (\$0.50 / \$2.50 per 1M input / output) and average token usage of 25.5K input and 6.5K output per query.

Dimension	gpt-4.1		gpt-5.5	gpt-4.1	Kimi
	gpt-4.1	+web	+web	(Asst.)	K2.5
Content quality	4.10	4.00	5.00	4.00	4.60
Contextual adaptation	4.60	4.40	5.00	4.50	5.00
Evidence citation	3.60	4.00	5.00	3.80	4.10
Implementability	4.20	4.50	4.60	4.10	4.20
Regulatory alignment	3.90	3.90	4.90	4.10	4.20
Source attribution	4.20	4.50	4.50	3.80	4.10
Resource consideration	2.00	2.00	3.20	1.60	2.50
Average	3.83	3.90	4.60	3.70	4.15
Std. dev.	0.91	0.89	0.82	1.01	0.94
Cost / query (USD)	~0.02	~0.03	~0.77*	~0.07	~0.03
Latency (s)	33	30	278	41	36
Tokens leaving EU	all	all	all	all	0

6 Discussion

6.1 Backbone Selection Within the Same RAG Architecture

The 10/0 pairwise result and the per-dimension gap analysis establish that, under equal conditions, Kimi K2.5 substantially outperforms DeepSeek V3.2 on dimensions requiring normative traceability. The concentration of the gap on source attribution ($\Delta = 1.80$) and regulatory alignment ($\Delta = 1.30$) suggests that the two models differ in their ability to follow structured citation directives — a finding that is independent of prompt design, since both models received identical instructions. Implementability ($\Delta = 0.60$, 3 ties) is the sole dimension where the models converge, suggesting that general instruction-following is comparable but domain-specific citation discipline is not.

A natural question is why the backbone selection did not include Mistral Large, the most capable EU-origin open-weight model at the time of the experiments. Mistral was considered as a third candidate: preliminary pilot scoring on the 7-criterion rubric placed it below both Kimi K2.5 and DeepSeek V3.2, and it was therefore not advanced to the full benchmark. We report this transparently: the choice of benchmarking the best-performing open-weight backbone available, rather than the most sovereignty-compliant one, leaves the EU-origin

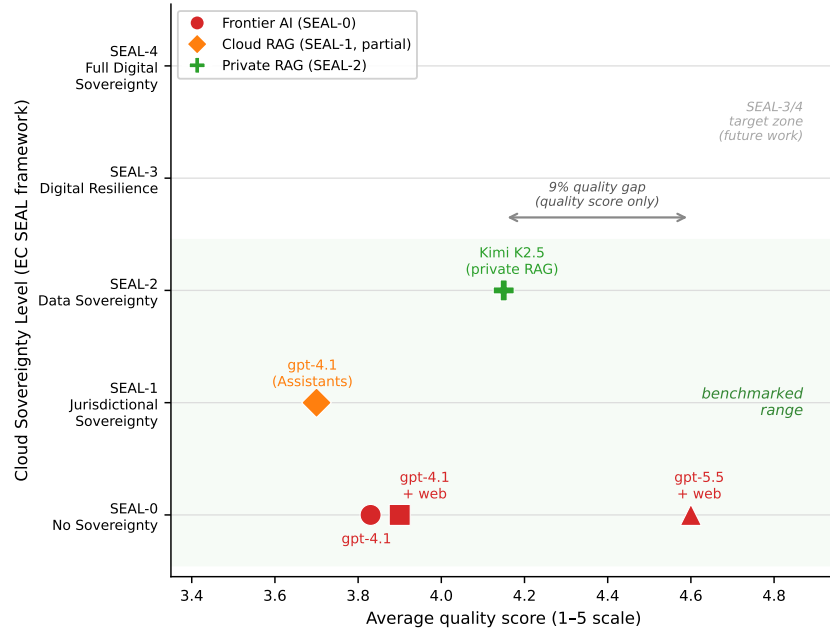


Fig. 3. Quality vs. privacy posture for the five benchmarked configurations. The 9% quality gap between the best frontier configuration (gpt-5.5 + web, avg. 4.60) and the private RAG configuration (Kimi K2.5, avg. 4.15) corresponds to a jump from SEAL-0 to SEAL-2 compliance.

sovereignty–quality trade-off (the SEAL-3 path discussed in Section 4 and Section 7) empirically uncharacterised. Sovereignty and quality are orthogonal dimensions; the paper quantifies both separately, and the path from SEAL-2 to SEAL-3 via a Mistral-based backbone is identified as future work precisely because it carries a quality cost that has not yet been measured under the present rubric.

6.2 Frontier Benchmark Interpretation

The 9% quality gap between the best frontier configuration (gpt-5.5 + web search, avg. 4.60) and the private RAG configuration (Kimi K2.5, avg. 4.15) is concentrated in ctx-H, where the Italian regulatory web corpus is rich and live web search provides substantive grounding. The gap halves in ctx-M (NATO classified), precisely the context where privacy posture matters most and where web search offers the least domain-specific value.

The apparent advantage of gpt-5.5 + web search must be discounted by three caveats: two processors without DPA (OpenAI and Bing), more than $25\times$ higher cost (token-only; $\sim 35\times$ including web search tool fees), $7\times$ higher latency, and citations drawn from blogs and vendor whitepapers rather than institutional

sources. The audit trail of a private RAG with a curated KB is deterministic and reproducible; the audit trail of a frontier model with live web search is neither.

7 Conclusion

For regulated organisations the question is not “which model writes the best policy” but “which architecture produces adequate policies under the constraint that no data shall leave the perimeter.” A private RAG on EU-resident open-weight models is today a technically competitive option: it achieves 90% of frontier quality at one-tenth the cost, with full GDPR compliance and a deterministic audit trail. The marginal quality gain offered by frontier AI models does not justify the privacy cost they impose.

A further open question concerns the relative weight of two distinct privacy properties: *legal domicile* of the provider versus *physical residency* of the data. A provider legally incorporated in the EU but operating sub-processors outside the EU may, in practice, offer weaker GDPR protection than an EU-domiciled provider with a clean sub-processor chain, even if the latter is less well-known. Conversely, a non-EU provider (e.g., subject to the US CLOUD Act) that operates servers exclusively in an EU region may offer strong data residency guarantees while remaining legally exposed to extra-EU compelled disclosure. Our experimental setup treats GDPR compliance as a binary dimension assessed from published provider documentation; a more nuanced analysis should evaluate the full sub-processor chain and the legal jurisdiction of each entity in the inference path. We leave this as a direction for future work.

These considerations are acquiring regulatory urgency. In April 2026 the European Commission awarded its first procurement contract under the Cloud Sovereignty Framework [5], which defines five Sovereignty Effectiveness Assurance Levels (SEAL-0 to SEAL-4) and sets SEAL-2 as the minimum threshold for EU institutional procurement. Under this framework, frontier AI providers incorporated outside the EU qualify at SEAL-0 at best, regardless of server location; all four winning consortia are EU-incorporated. The private RAG architecture evaluated in this paper — EU-resident open-weight models under a DPA with an EU-incorporated provider — aligns structurally with SEAL-2 requirements, making the 9% quality gap relative to the best frontier configuration the operational cost of regulatory-grade sovereignty. The adequacy basis underpinning US transfers, the EU–US Data Privacy Framework [4], meanwhile faces continued uncertainty: the General Court upheld it in September 2025 [9], but the case is on appeal before the CJEU, and the temporary loss of quorum of the Privacy and Civil Liberties Oversight Board — a structural redress pillar of the framework — illustrates the fragility of building long-term GDPR compliance on executive-dependent mechanisms. The GDPR and the CLOUD Act are therefore in structural, not episodic, conflict [2,15]: two sovereign legal orders asserting concurrent jurisdiction over the same data. The Cloud Sovereignty Framework [5] represents the first objective metric for distinguishing verifiable legal sovereignty from superficial geographic residency claims. For AI-assisted policy generation in

Table 3. Per-objective sovereignty assessment for the private RAG configuration (Kimi K2.5 on Nebius EU). Objectives and SEAL levels follow the EC Cloud Sovereignty Framework v1.2.1 [5].

SOV	Dimension	Assessment	SEAL
SOV-1	Strategic	EU-based AI infrastructure (NL), NASDAQ-listed; partial EU ecosystem anchoring	SEAL-2
SOV-2	Legal/Juris.	EU-incorporated provider; no CLOUD Act exposure; Moonshot AI (CN) raises Chinese Cybersecurity Law question at model layer	SEAL-2
SOV-3	Data & AI	Data confined to EU; open-weight model auditable; training origin outside EU (Moonshot AI)	SEAL-2
SOV-4	Operational	Open-weight portability enables EU-operated self-hosting; residual Nebius API dependency	SEAL-2/3
SOV-5	Supply Chain	NVIDIA hardware (US); Kimi K2.5 weights (CN); material non-EU supply chain	SEAL-1/2
SOV-6	Technology	Open-weight licence; auditable weights; standard APIs	SEAL-2/3
SOV-7	Security	GDPR Art. 28 DPA; NIS2-aligned; EU certification status of Nebius unverified	SEAL-2
SOV-8	Environmental	Out of scope for this study	—

regulated EU contexts, a provider’s SEAL level is a criterion complementary to, and arguably more discriminating than, ISO/IEC 27001 certification or server location alone. Table 3 disaggregates this claim by sovereignty objective, providing per-dimension evidence for the SEAL-2 alignment assessment of the private RAG configuration evaluated in this paper.

Across assessed dimensions, the configuration demonstrates SEAL-2 alignment consistently, in line with the framework definition: *EU law applicable and enforceable, with material non-EU dependencies remaining* [5]. The principal non-EU dependencies are the model supply chain (Moonshot AI, CN) and hardware (NVIDIA, US); both qualify as material rather than marginal, precluding SEAL-3 under the current architecture.

Several limitations bound the scope of this study. First, the benchmark covers only two synthetic organisational contexts (Italian public hospital and NATO detachment) and five policy types; broader coverage across sectors, jurisdictions, and real-world organisations is needed before general conclusions can be drawn. Second, evaluation relies on a single LLM judge (Claude Opus 4.7); no formal significance testing was performed, and results constitute descriptive comparative evidence rather than statistically warranted claims. Cross-validation against a second judge model is left as future work. Third, human calibration yields $\kappa_w = 0.65$ in the initial round and $\kappa_w = 0.28$ in the extended external round; the lower value in the extended round reflects diverse rater backgrounds rather than judge unreliability, as rank ordering was fully preserved ($\kappa = 1.0$). No validation by operational CISOs or legal experts was performed; such practitioner review would strengthen the practical validity of the conclusions. Fourth,

sovereignty and GDPR conclusions are assessed from provider-published documentation and contractual commitments, not from independent technical audit of sub-processor chains or legal jurisdiction — a more rigorous evaluation should verify the full legal exposure of each entity in the inference path. Fifth, cost estimates for gpt-5.5 + web search are preliminary pending stable API pricing.

A natural next step is to characterise the path from the current SEAL-2 private RAG architecture to SEAL-3. The binding constraint is the model backbone: Kimi K2.5 is developed by Moonshot AI (China) and its weights depend on an entity subject to the Chinese National Intelligence Law, creating a residual non-EU supply-chain dependency. A SEAL-3 configuration would require replacing the backbone with an EU-origin model — Mistral being the most mature candidate — deployed on SEAL-3-certified infrastructure (OVHcloud, STACKIT, or Scaleway), together with a locally hosted embedding model to remove the remaining Nebius API call from the retrieval pipeline. Notably, this requirement is not satisfied by Mistral’s primary commercial channels: API access via Microsoft Azure — Mistral’s strategic distribution partner since 2024 [14] — is subject to CLOUD Act extraterritorial reach, whilst Mistral’s own managed platform (la.pplateforme.ai) does not carry explicit SEAL-3 certification under the EC Cloud Sovereignty Framework [5]. EU-origin model selection and SEAL-3-certified deployment infrastructure are therefore orthogonal requirements that must both be satisfied independently. Whether this full architectural upgrade preserves the observed quality level relative to frontier systems is an open empirical question.

Experimental code and generated policy artefacts are available at <https://github.com/lisboncouncil/cocyber-policycoach> to support reproducibility.

Acknowledgements

This work has been carried out within the COcyber project (*Coordination Between the Cybersecurity Civilian and Defence Spheres*), which has received funding from the European Union’s Digital Europe Programme (DIGITAL) under Grant Agreement No. 101158606 (Call DIGITAL-ECCC-2023-DEPLOY-CYBER-04).

Views and opinions expressed are however those of the author(s) only and do not necessarily reflect those of the European Union or the European Cybersecurity Competence Centre (ECCC). Neither the European Union nor the granting authority can be held responsible for them.

References

1. Anthropic: Demystifying evals for AI agents. Anthropic Engineering Blog (2024), <https://www.anthropic.com/engineering/demystifying-evals-for-ai-agents>, accessed: May 2026
2. Court of Justice of the European Union: Data protection commissioner v. Facebook Ireland Ltd and Maximillian Schrems. Case C-311/18, ECLI:EU:C:2020:559 (2020)

3. Dubois, Y., Li, C.X., Taori, R., Zhang, T., Gulrajani, I., Ba, J., Guestrin, C., Liang, P., Hashimoto, T.B.: AlpacaFarm: A simulation framework for methods that learn from human feedback. In: *Advances in Neural Information Processing Systems*. vol. 36 (2023)
4. European Commission: Commission implementing decision (EU) 2023/1795 on the adequate level of protection of personal data under the EU-US data privacy framework. *Official Journal of the European Union*, L 231/118 (2023)
5. European Commission: Cloud sovereignty framework (SEAL): Commission advances cloud sovereignty through strategic procurement. Press release, 17 April 2026 (2026), https://commission.europa.eu/news-and-media/news/commission-advances-cloud-sovereignty-through-strategic-procurement-2026-04-17_en
6. European Parliament and Council of the European Union: Regulation (EU) 2016/679 on the protection of natural persons with regard to the processing of personal data (GDPR). *Regulation, Official Journal of the European Union* (2016)
7. European Parliament and Council of the European Union: Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the union (NIS2). *Directive, Official Journal of the European Union* (2022)
8. European Parliament and Council of the European Union: Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (AI act). *Regulation, Official Journal of the European Union* (2024)
9. General Court of the European Union: *Latombe v. commission*, case T-553/23. Judgment of 3 September 2025 (2025), appeal pending before the CJEU
10. Jawhar, S., Miller, J.R., Bitar, Z.: AI-based cybersecurity policies and procedures. In: *Proc. 3rd IEEE Int. Conf. on AI in Cybersecurity (ICAIC)*. Houston, TX, USA (2024). <https://doi.org/10.1109/ICAIC60265.2024.10433845>
11. Landis, J.R., Koch, G.G.: The measurement of observer agreement for categorical data. *Biometrics* **33**(1), 159–174 (1977)
12. Liu, Y., Iter, D., Xu, Y., Wang, S., Xu, R., Zhu, C.: G-Eval: NLG evaluation using GPT-4 with better human alignment. In: *Proc. 2023 Conf. on Empirical Methods in Natural Language Processing (EMNLP)* (2023)
13. McIntosh, T.R., Liu, T., Susnjak, T., Alavizadeh, H., Ng, A., Nowrozy, R., Watters, P.: Harnessing GPT-4 for generation of cybersecurity GRC policies: A focus on ransomware attack mitigation. *Computers & Security* **134**, 103424 (2023). <https://doi.org/10.1016/j.cose.2023.103424>
14. Microsoft: Microsoft and Mistral AI announce new partnership to accelerate AI innovation and introduce Mistral Large, first on Azure. *Microsoft Azure Blog*, 26 February 2024 (2024)
15. United States Congress: Clarifying lawful overseas use of data act (CLOUD act). Pub. L. 115-141, Title VII (2018)
16. Zheng, L., Chiang, W.L., Sheng, Y., Zhuang, S., Wu, Z., Zhuang, Y., Lin, Z., Li, Z., Li, D., Xing, E.P., Zhang, H., Gonzalez, J.E., Stoica, I.: Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena. In: *Advances in Neural Information Processing Systems*. vol. 36 (2023)